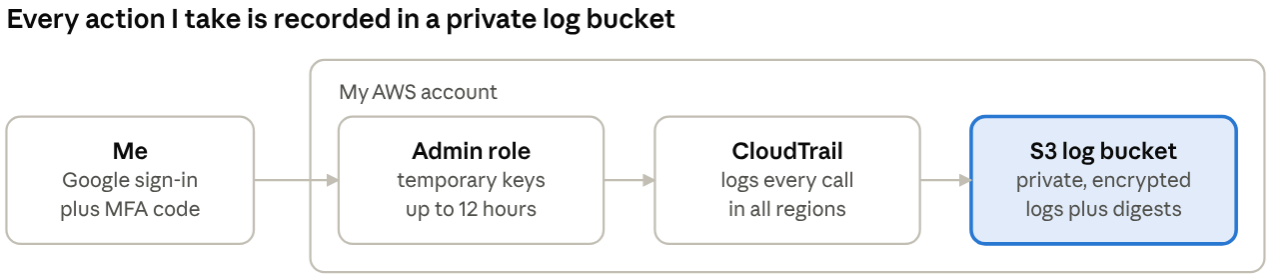
AWS Cloud Security: Project 1

Oct 31, 2026 · @Poovanna M D

Project 1 at a glance

I built a protected, logged and cost-capped AWS account without writing code, and proved the logging works.



Project 1 · sign-in to log bucket

I sign in with MFA, work through a temporary admin role, and CloudTrail writes every call into a private S3 bucket. A $5 budget alert watches spending for the whole account.

Basic terms

Ten words explain most of this document.

Term	Plain meaning
AWS	Amazon Web Services: I rent computers, storage and security tools over the internet and pay for what I use.
Account	My private space inside AWS. Everything I create lives in it.
Region	A geographic area where AWS runs data centers, such as Sydney (`ap-southeast-2`). Most resources live in one region.
API call	A request to AWS to do something, like "create a bucket". Every click in the console sends one.

Term	Plain meaning
S3 bucket	A container for storing files in Amazon S3. Bucket names are unique across all of AWS. Mine holds the CloudTrail log files.
CloudTrail	The service that records who did what in my account, and when. Think of it as a security camera.
Event	One recorded API call in CloudTrail.
Log	A written record of events. Analysts use logs as evidence when investigating.
IAM	Identity and Access Management: the service that controls who can do what.
MFA	Multi-factor authentication: a second code from my phone on top of my password.

1. Sign-in protection (Builder ID and MFA)

My account is protected by a second factor, so a stolen password alone cannot open it.

- **AWS Builder ID:** my AWS sign-in identity. I sign in with Google, so my Google account is the real front door. I keep its 2-Step Verification on.
- **MFA (multi-factor authentication):** a one-time code from an authenticator app on my phone, on top of my normal login. Mine is a TOTP device named `builder-id-phone`.
- **Recovery email:** a second personal email that lets me regain access if I lose my main sign-in method. I never use a work email for it.
- **Why it matters:** most account takeovers start with a stolen or reused password. MFA stops the attacker at the second step.
- **Remember:** MFA is asked at a fresh Builder ID sign-in. Signing out of only the console session does not ask for it, but signing out of AWS fully and back in does. CloudTrail still showed `mfaAuthenticated: false`, so that field did not reflect this MFA.

2. IAM: who can do what

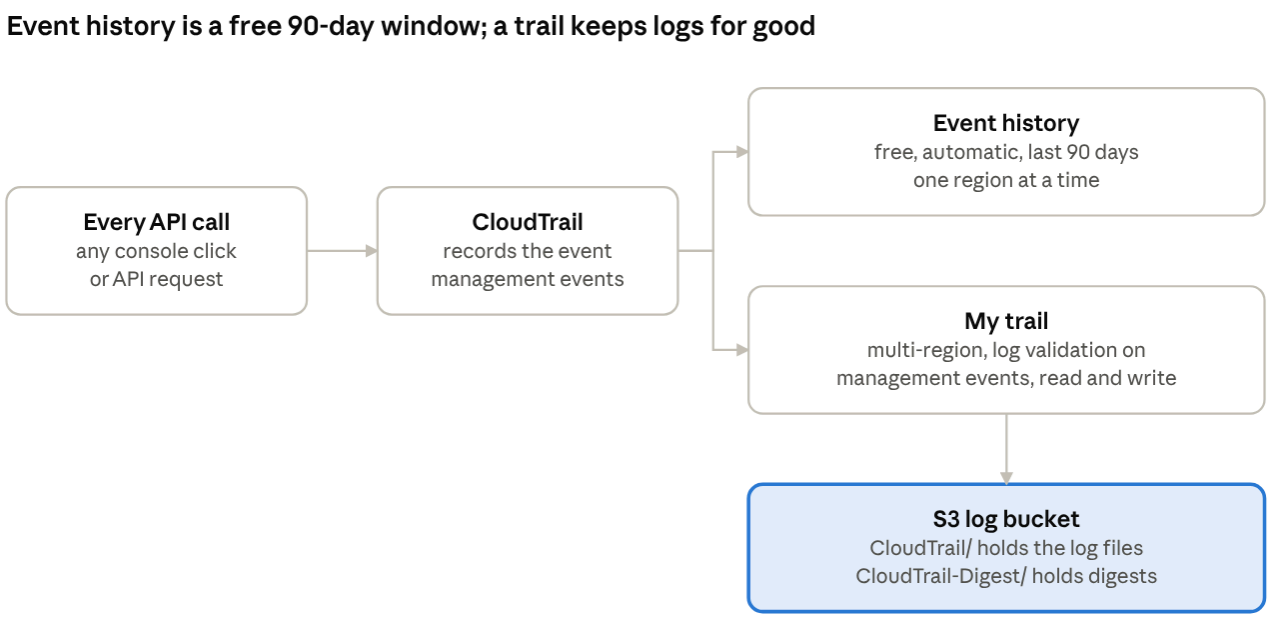
I work through a role with temporary credentials, not an IAM user with permanent keys, and that role is full admin.

Term	Plain meaning	In my account
IAM	The service that controls who can do what in AWS	Dashboard under IAM
IAM user	A person or program with long-term credentials (keys, password)	None, 0 users
Role	An identity you assume temporarily, with short-lived credentials	`AccountFullAccessRole`
Policy	A list of allowed actions	`AdministratorAccess` (allows everything)
Permissions boundary	A ceiling that limits a role's maximum permissions	Not set
Root access management	A short privileged session for root-only fixes, such as deleting a broken S3 bucket policy	Available, unused

- **Session length:** up to 12 hours, then credentials expire on their own.
- **Least privilege:** give an identity only the permissions it needs. Admin is the opposite, so it is fine for learning, and later automation (like Lambda) gets narrow roles.
- **Why roles beat users:** a leaked temporary credential expires. A leaked permanent key keeps working until someone finds and deletes it.
- **I do not edit or delete** `AccountFullAccessRole`. It is how I reach my own account.

3. CloudTrail: my account's security camera

Event history is a free 90-day view of what happened; my trail keeps the same events for good.

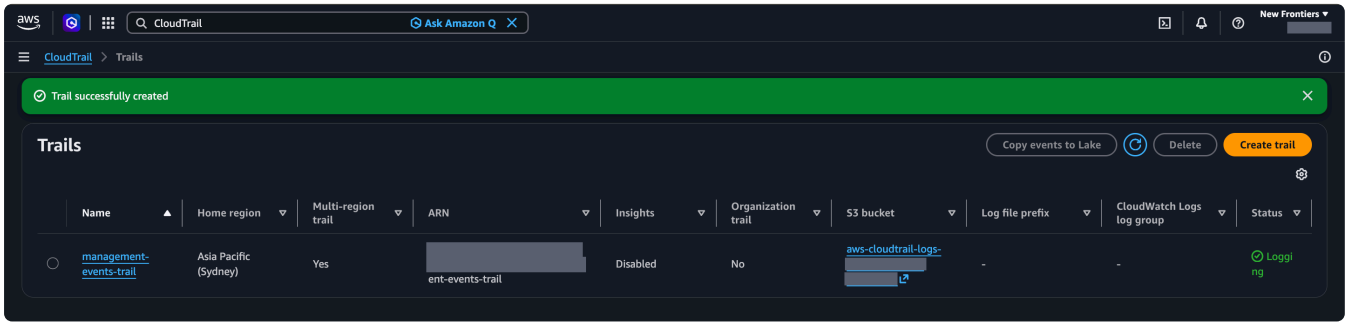


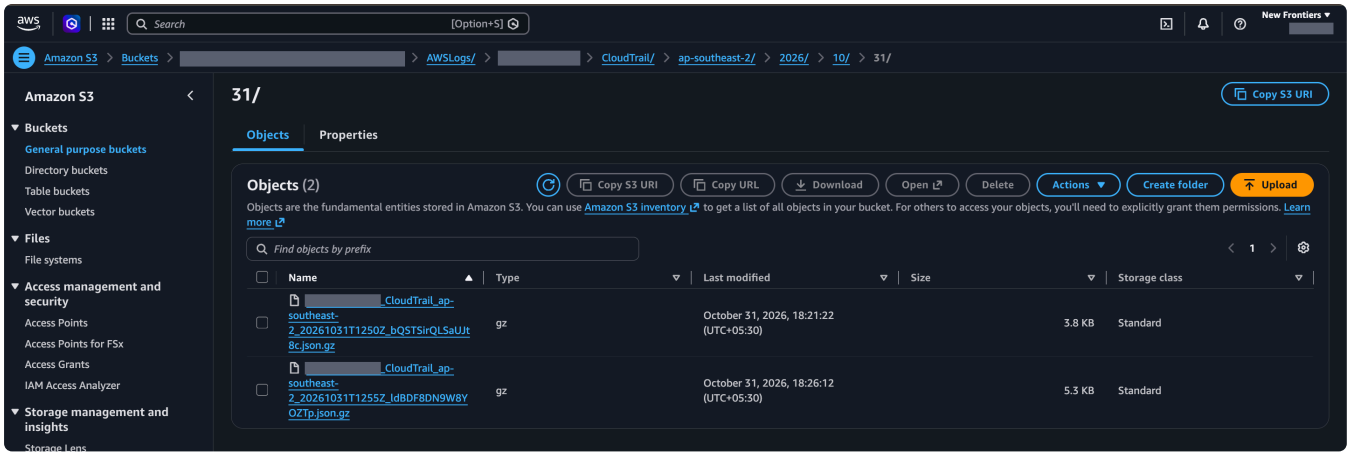
CloudTrail · event history vs trail

Every call is recorded once, then shown two ways: the quick 90-day view, and permanent files in my bucket.

- **Management events:** actions that create, change or delete things. My trail logs these, read and write, at no extra charge because it is my first copy.
- **Log files:** `.json.gz` batches in my bucket under `AWSLogs/<account-id>/CloudTrail/<region>/<date>/`. A new file arrives every few minutes.
- **Digest files:** signed summaries in `CloudTrail-Digest/`, created by log file validation. They let me prove logs were not altered.
- **Encryption:** default S3 encryption. The custom KMS key option is off to avoid cost.
- **Left off on purpose:** data events, Insights, network activity events, CloudWatch Logs and SNS, because each can add charges.
- **I never change or delete** anything inside the log bucket. CloudTrail needs its policy and folders exactly as they are.

Proof from my own account: the trail shows Logging and is multi-region, and log files are arriving in the bucket. Account details are hidden with gray boxes.



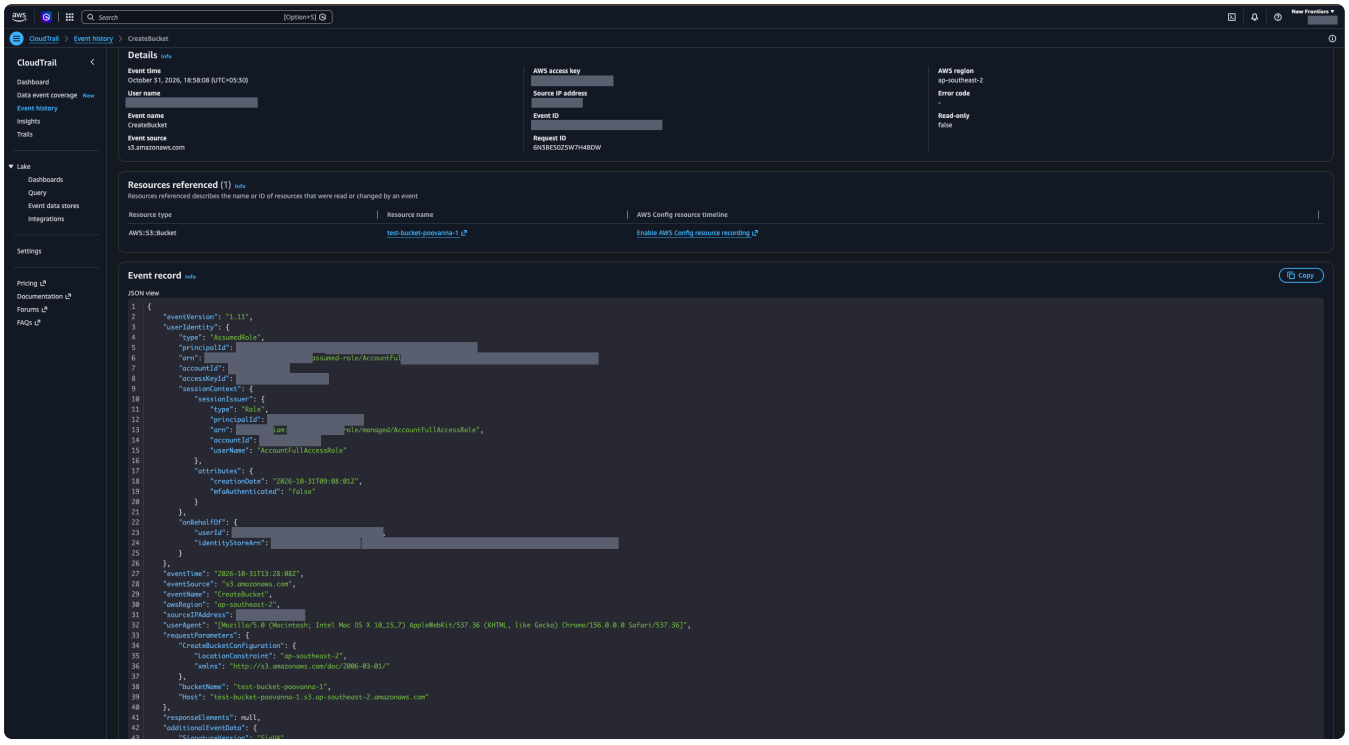


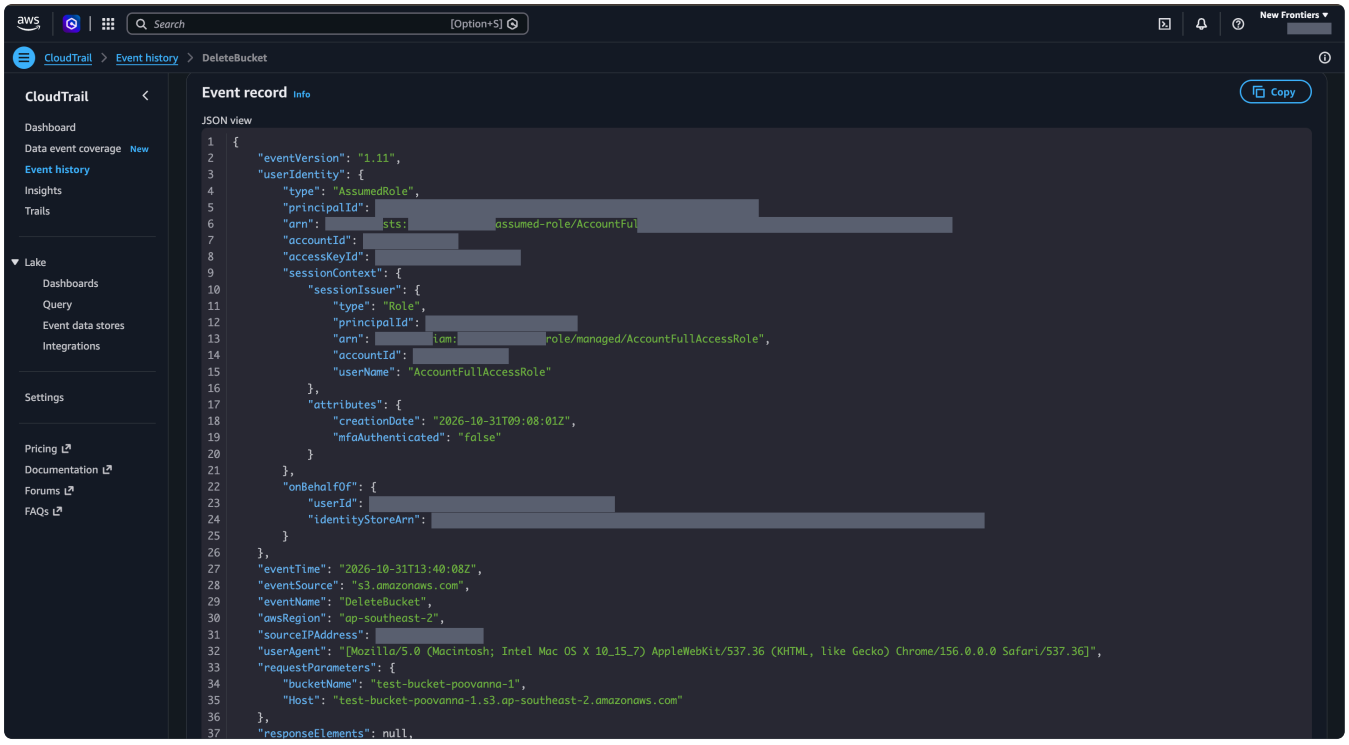
4. Reading an event record

Every event answers who, what, when, where and how, and I can read my own test the same way an analyst would.

Question	Field	My CreateBucket test
Who	`userIdentity`	`AssumedRole`, role `AccountFullAccessRole`
What	`eventName`, `requestParameters`	`CreateBucket`, bucket `test-bucket-poovanna-1`
When	`eventTime` (UTC)	13:28:08 UTC = 18:58 IST
Where	`awsRegion`	`ap-southeast-2` (Sydney)
From where	`sourceIPAddress`	My own public IP address
With what	`userAgent`	Chrome on Mac, so a human in the console
Changed anything?	`readOnly`	`false` (a write event)
MFA session?	`mfaAuthenticated`	`false` (MFA is enforced at sign-in, but this field did not show it)

My own events in CloudTrail: the CreateBucket event, then the DeleteBucket event about 12 minutes later. Read them with the table above. Account details are hidden with gray boxes.





AWS acting on its own looks different: `invokedBy` is a service, `sourceIPAddress` is a service name like `ec2.amazonaws.com`, `eventType` is `AwsServiceEvent`, and no access key is involved. My default network creation at sign-up was like this, and it is normal.

What an analyst looks for as suspicious:

- An IP address nobody recognises
- A script or command-line tool as `userAgent` when a person would use the console
- An `errorCode`, meaning something failed or was denied
- Activity in a region you never use

- Deletions or changes to logging itself

5. Interview questions with short answers

Practice answers, in my own words, using what I built.

Question	Short answer
Why use roles instead of IAM users?	Roles give temporary credentials that expire. A leaked permanent key keeps working until someone deletes it.
What is least privilege?	Give an identity only the permissions it needs. My admin role is the opposite, so automation gets narrow roles.
Event history vs a trail?	Event history is a free, automatic 90-day view of management events in one region. A trail saves logs to S3 permanently, in all regions if multi-region.
Why a multi-region trail?	Attackers often use regions I never look at. One trail covers them all.
What does log file validation do?	It adds signed digest files so I can prove logs were not changed or deleted.
Why keep logs in a private, encrypted bucket?	Logs are evidence. They must stay private and intact.
How do you tell a human action from AWS acting on its own?	Check userIdentity, sourceIPAddress and userAgent. Services show a service name and eventType AwsServiceEvent.
How do you guard against surprise bills?	Use the Free plan, a budget alert at low thresholds, and delete test resources.
How would you scale this to 50 accounts?	AWS Organizations, an organization trail, service control policies, and centralized logging.
What does this setup still lack?	Managed threat detection (GuardDuty is not available on my account type, so I studied it as a concept), automated alerts, and narrow least-privilege roles.